GETAMAZEDNOW AI

PRACTICAL AI. POSSIBLE FUTURES.

A GETAMAZEDNOW COMPANY

A D S R A

Australian Digital Sovereignty Reference Architecture

Technical Reference for Engineering, Architecture, Security and Risk Teams

Version 0.3 — Draft for Peer Review

Author: Duane Gomes October 2026



Document Control

Item	Detail
Title	ADSRA — Australian Digital Sovereignty Reference Architecture: Technical Reference
Version	0.3 (draft for peer review; supersedes the July 2026 draft v0.2)
Author	Duane
Date	October 2026 (regulatory position as at 2 October 2026)
Audience	Enterprise, solution and security architects; platform, cloud and AI engineering; risk and compliance partners
Companion artefacts	ADSRA Executive Briefing (PowerPoint); ADSRA White Paper and article series
Review status	Open items and peer-review questions are listed in Section 14

> **Draft integrity statement.** Every regulatory claim in this document is anchored to a primary source in Section 13 (References) and traced in Section 12 (Evidence Register). Where a position is the author's professional judgement rather than a regulatory requirement, it is explicitly marked [Position]. Items described as proposed, announced or draft are not obligations and are labelled as such. Reviewers are asked to challenge both.

Contents

Document Control 2
Contents 3
1. Introduction and Purpose 5
1.1 Why this document exists 5
1.2 Audience and how to use this document 5
1.3 Scope and non-goals 5
2. Definitions and Sovereignty Tiers 6
2.1 Working definitions 6
2.2 Sovereignty tiers 6
3. Australian Regulatory Obligation Matrix 7
4. The ADSRA Layered Model 10
4.1 Design principles 10
5. Cross-Cutting Runtime Architecture 11
5.1 Shared service obligations 11
6. The Seven Sovereignty Pillars 12
6.1 Pillar 1 — Data Sovereignty 12
6.2 Pillar 2 — Identity Sovereignty 13
6.3 Pillar 3 — Cryptographic Sovereignty 14
6.4 Pillar 4 — Operational Sovereignty 15
6.5 Pillar 5 — AI Sovereignty 16
6.6 Pillar 6 — Governance Sovereignty 18
6.7 Pillar 7 — Observability Sovereignty 19
7. AI Sovereignty Reference Flow (Detailed) 21
7.1 Worked example — retail AI pricing assistant 21
7.2 Worked example — bank customer-service copilot 21
8. The Reference Capability Model 22
9. The ADSRA Maturity Model 23
10. Industry Blueprints 25
10.1 Banking 25
10.2 Financial services and superannuation 25
10.3 Retail 25
10.4 Healthcare 25
10.5 Utilities 26
10.6 Education 26
11. Metrics, Assurance and Implementation 27
11.1 KRI catalogue (Board-level subset) 27
11.2 Operating model 27
11.3 Three-horizon roadmap 27
11.4 Anti-patterns 28

12. Evidence Register (Claims → Sources) 29
13. References 31
14. Open Issues and Peer-Review Questions (v0.3) 33

1. Introduction and Purpose

ADSRA is a reference architecture that enables Australian organisations to leverage global cloud and AI platforms while maintaining sovereignty over data, identity, cryptography, operations and AI, in accordance with Australian regulatory and business obligations. It treats digital sovereignty as a first-class enterprise architecture domain — with named capabilities, control objectives, reference patterns, a maturity model and operational metrics — rather than as a compliance afterthought.

1.1 Why this document exists

Existing frameworks each solve part of the problem: TOGAF provides architecture method; SABSA provides business-attribute-driven security architecture; the cloud providers' well-architected frameworks provide workload guidance; and the ASD Information Security Manual (ISM) provides a controls catalogue. None of them treats jurisdictional control — who can compel, administer, decrypt, observe or infer over an enterprise's digital estate — as an architectural domain in its own right. ADSRA fills that gap for Australian and Asia-Pacific regulated enterprises. [Position]

1.2 Audience and how to use this document

- Enterprise and solution architects: use Sections 4–8 as the target-state reference and Section 9 for capability planning.
- Platform, cloud, data and AI engineers: use the control objectives (ADSRA-XX-nn) and technology mappings in Section 6 as build requirements.
- Security, risk and compliance partners: use Section 3 (obligation matrix), Section 11 (KRIs) and Section 12 (evidence register).
- Architecture boards and design authorities: use the maturity model (Section 10) and the roadmap guidance (Section 11.3) to sequence investment.

1.3 Scope and non-goals

In scope: public cloud (AWS, Azure, Google Cloud), private cloud, SaaS, enterprise data and integration platforms, and AI systems (predictive and generative, including agentic patterns). Out of scope: national-security-classified systems (SECRET and above), defence-specific supply-chain regimes (e.g., DISP), and physical/personnel security beyond what SOCI CIRMP requires of the covered sectors.

> **Relationship to method frameworks.** ADSRA is method-neutral. In TOGAF terms it supplies reference models and building blocks consumable in Phases B–D and governance in Phase G/H; in SABSA terms its pillars express as business attributes with traceable control objectives.

2. Definitions and Sovereignty Tiers

2.1 Working definitions

Term	Definition (as used in ADSRA)
Digital sovereignty	The demonstrable ability of an organisation to control who can access, administer, decrypt, observe, move or infer over its digital assets — and under which legal jurisdiction those actions occur.
Data residency	The physical/geographic location where data is stored and processed. Residency is necessary but not sufficient for sovereignty: jurisdiction follows the controlling entity, not only the data centre.
Jurisdictional exposure	The set of foreign legal instruments (e.g., the US CLOUD Act) that could compel a provider in the enterprise's supply chain to produce data or take action, irrespective of storage location.
Operational sovereignty	Control over who administers production systems, from which country, with what privilege, and with what evidence trail.
AI sovereignty	Control over where and how prompts, embeddings, retrieval corpora, inference, training/fine-tuning and model telemetry are processed, and by whom.
Sovereignty tier	A classification level (Low / Medium / High / Critical) that determines the mandatory control set a workload or data asset inherits.

2.2 Sovereignty tiers

Classification is the engine of ADSRA: it prices controls so that low-risk assets are not taxed with Critical-tier costs, and Critical assets are never under-protected.

Tier	Typical assets	Mandatory control posture (summary)
★ Low	Public content, product catalogues, marketing assets	Any region; provider-managed encryption; standard logging
★★ Medium	Pricing, commercial documents, non-identifying analytics	AU-region preferred; CMK optional; DLP monitoring
★★★ High	Customer profiles, loyalty behaviour, staff records	AU residency; customer-managed keys; tokenised identifiers; PIA; conditional access
★★★★ Critical	Payment credentials, health records, credentials/keys, regulated ledgers	AU residency and AU operations; HSM-backed CMK or HYOK; client-side encryption where feasible; privileged session recording; AU SOC; tested exit plan

> **Calibration guidance.** Tier assignment should be justified against the obligation matrix in Section 3 and reviewed annually. Over-classification is a named anti-pattern (Section 11.4): it erodes delivery velocity and the credibility of the scheme.

3. Australian Regulatory Obligation Matrix

The matrix below maps the principal instruments to the ADSRA pillars they exercise. Dates are as at 2 October 2026; verify currency before relying on this table for compliance decisions. Full citations appear in Section 13.

Instrument	Key obligations relevant to ADSRA	Key dates	Primary pillars
APRA CPS 230 Operational Risk Management [R1]	Identify critical operations and Board-approved tolerance levels; manage material service providers (MSPs) incl. fourth parties; notify APRA within 24 hours of a disruption to a critical operation outside tolerance, and within 72 hours of a material operational risk incident; maintain tested BCP and exit plans	In force 1 Jul 2025; pre-existing MSP contracts by earlier of renewal or 1 Jul 2026 (passed); targeted amendments final 30 Apr 2026, effective 1 Jul 2026 — narrow relief from specified contractual requirements for non-traditional providers (government agencies, regulators, central banks, market infrastructure); notification clocks unchanged	Operations, Governance, Observability, Data
APRA CPS 234 Information Security [R2]	Board-accountable information security capability commensurate with threats; control assurance across third parties; 72-hour incident notification to APRA	In force since 1 Jul 2019	Identity, Crypto, Operations, Observability
Privacy Act 1988 (Cth), as amended 2024 [R3, R4]	APPs incl. cross-border disclosure (APP 8); statutory tort for serious invasions of privacy; tiered civil penalties (up to the greater of $50m or 3× the benefit obtained — or, where the benefit cannot be determined, 30% of adjusted turnover — for a serious interference with privacy under s 13G; amounts set by the 2022 amendment); automated-decision transparency in privacy policies (new APP 1.7–1.9): disclose the kinds of personal information used by programs that make, or do a thing substantially and directly related to making, decisions that could significantly affect individuals' rights or interests, and the decision types involved	2024 Act assent 10 Dec 2024; tort live by Jun 2025; ADM transparency from 10 Dec 2026 (OAIC final guidance Sep 2026); Children's Online Privacy Code — draft; must be registered by 10 Dec 2026 (statutory deadline)	Data, AI, Governance
SOCI Act 2018 (Cth) + CIRMP Rules [R5]	Critical Infrastructure Risk Management Program across cyber, personnel, supply-chain and physical hazards; asset register; mandatory cyber incident reporting; enhanced obligations for Systems of National Significance. Covers 11 sectors incl. financial	CIRMP obligations phased from 2023; Enhanced CIRMP Rules commenced 10 Jun 2026 (12/24-month windows: 10	Operations, Governance, Observability, Identity

Instrument	Key obligations relevant to ADSRA	Key dates	Primary pillars
	services, healthcare, energy, data storage/processing. Enhanced CIRMP Rules uplift obligations for specified asset classes (electricity, gas, water, liquid fuel, freight, energy market operator, broadcasting, DNS). Tranche 2 reforms (21 measures incl. managed-service-provider and supply-chain duties, provider-facing criteria for data storage/processing, AI-related incident definitions) are proposed, not law	Jun 2027 / 10 Jun 2028; 12-month items reportedly include foreign ownership, control and influence and offshore remote access); Tranche 2 consultation closed 31 Jul 2026	
ASD ISM & Essential Eight [R6]	Baseline control catalogue and maturity model for cyber hardening; IRAP assessments provide independent control assurance for cloud services against the ISM	ISM updated regularly (quarterly cadence)	All pillars (control baseline)
Hosting Certification Framework (DTA/Home Affairs) [R7]	Certified Strategic / Certified Assured tiers over ownership, control, operations and supply chain of hosting providers; required for sensitive government data and PROTECTED systems (applies to new contracts from 30 Jun 2022). Instructive for private-sector provider due diligence	Framework released Mar 2021; reform under way; new registrations paused from 3 Nov 2025 (completion date unconfirmed)	Operations, Governance
My Health Records Act 2012 (Cth) [R8]	My Health Record system data must be held and processed in Australia; prohibitions on taking the data outside Australia	In force (2012)	Data, Operations, AI
US CLOUD Act 2018 [R9]	US authorities may compel providers subject to US jurisdiction to produce data in their possession, custody or control, regardless of storage location — the canonical reason residency ≠ sovereignty. The Australia–US CLOUD Act Agreement (in force Jan 2024) streamlines serious-crime data requests in both directions; it does not change the analysis that jurisdiction follows the controlling entity [R22] [Position]	In force (2018); AU–US Agreement in force Jan 2024	Data, Crypto
AI policy: Guidance for AI Adoption (Oct 2025), National AI Plan (Dec 2025) [R10]	Voluntary AI Safety Standard (2024) superseded by the Guidance for AI Adoption (six essential practices); National AI Plan chose existing technology-neutral law plus an AI Safety Institute (operational 2026; advisory, not a regulator); the earlier mandatory-guardrail proposals were not taken up. On 15 Jul 2026 the Prime Minister announced mandatory Australian Standards for AI and an Office of AI — defined so far for large AI data centres and AI-training use of Australian creative work, not for enterprise AI use [R15]. High-risk AI expectations remain the design signal	GfAA Oct 2025; Plan Dec 2025; AISI operational 2026; PM announcement 15 Jul 2026; legislation expected early 2027 (announced, not law)	AI, Governance, Observability
APRA letter on AI [R14]	First AI-specific expectations of boards and accountable executives (banks, insurers, superannuation trustees): AI strategy within	Issued 30 Apr 2026	AI, Operations, Governance, Observability

Instrument	Key obligations relevant to ADSRA	Key dates	Primary pillars
	risk appetite; inventory of AI tools and use cases; human involvement in high-risk decisions; controls for AI-specific threats (prompt injection, autonomous agents, data leakage); map of the AI supply chain incl. fourth parties; contractual transparency and audit rights; concentration risk with credible exit/substitution; recognised control frameworks; second-line capability to assess probabilistic models and autonomous workflows; continuous monitoring proportionate to criticality. Expectations, not a new standard; the letter does not cite CPS 230/234 or sovereignty		
Government AI Standards and data-centre expectations [R15, R16]	Announced mandatory Australian Standards for AI and an Office of AI (PM&C); defined so far for large AI data centres (location, energy, water) and protection of Australian creative work from unconsented AI training. Five data-centre expectations: national interest incl. national security and data sovereignty; energy transition; water; skills and jobs; research and local capability. Not yet obligations on how enterprises use AI	Expectations 23 Mar 2026; announcement 15 Jul 2026; legislation expected early 2027 (scope, thresholds, enforcement unsettled)	AI, Operations
DTA Policy for the responsible use of AI in government v2.0 [R18]	In-scope Commonwealth agencies: AI impact assessment for each in-scope use case before deployment; internal register of use cases with accountable owners; strategic approach to AI adoption; procurement guidance. A benchmark for regulated industry	Effective 15 Dec 2025; impact-assessment requirement by 15 Dec 2026	AI, Governance
Cyber Security Act 2024 — ransomware payment reporting [R23]	Report a ransomware or cyber-extortion payment to ASD within 72 hours; applies to entities with annual turnover of $3m or more and responsible entities for critical infrastructure assets	Commenced 30 May 2025	Observability, Operations
Joint Select Committee on Artificial Intelligence [R20]	Examining the economic, legal, security and social dimensions of AI, including the adequacy of existing laws and data sovereignty. A watch item — it creates no obligation	Appointed 20 Aug 2026; final report due 30 Nov 2026	AI, Data

Reading the matrix. No single instrument requires 'sovereignty' by name. The architecture obligation emerges from their intersection: CPS 230 makes provider dependency a Board matter; the Privacy Act prices data mishandling; SOCI extends hazard management beyond cyber; the CLOUD Act makes jurisdiction a design variable; and the AI instruments make evidence of control the price of AI adoption. APRA's April 2026 AI letter is the first prudential statement of that expectation for the sectors it supervises. [Position]

4. The ADSRA Layered Model

ADSRA deliberately does not start with technology. It starts with control domains, placing the sovereignty layer between the enterprise's obligations and its platforms, so that every workload inherits sovereignty controls rather than negotiating them individually.

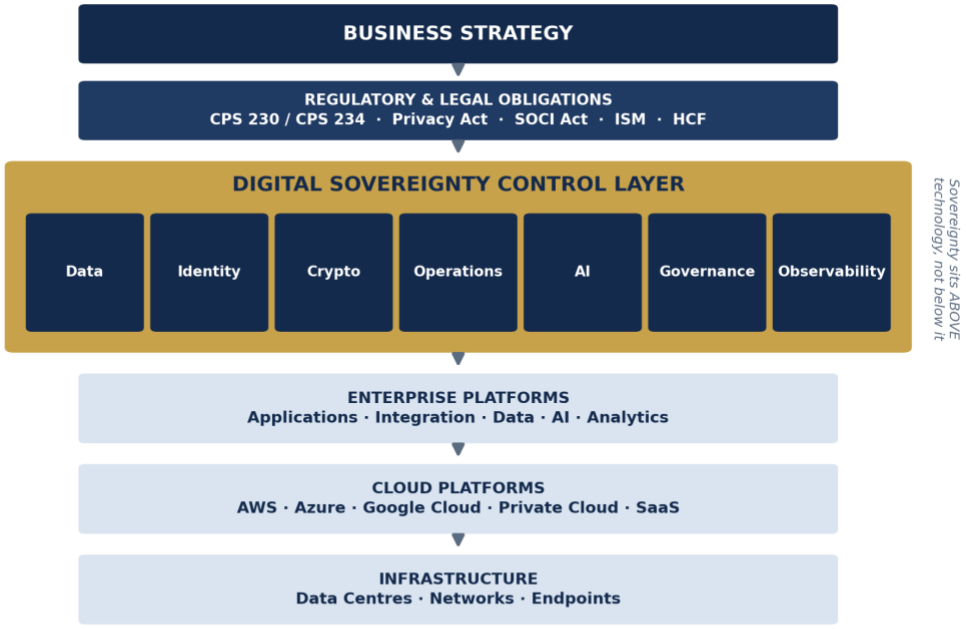


Figure 1 — ADSRA layered model: sovereignty as a first-class architecture layer

Figure 1 — The ADSRA layered model: sovereignty above technology, not below it.

4.1 Design principles

- Sovereignty above technology: controls are defined against obligations and classifications, then bound to platforms — never the reverse.
- Inheritance by default: workloads inherit the control set of their tier via landing zones, policy-as-code and shared services; exceptions are explicit, time-boxed and risk-accepted.
- Evidence or it didn't happen: every control emits telemetry to the observability pillar; a control without evidence is treated as absent.
- Price the premium: sovereign controls carry cost and capability trade-offs; classification exists to spend that premium only where obligations demand it.
- Method-neutral: ADSRA plugs into TOGAF/SABSA practice and coexists with cloud well-architected reviews.

5. Cross-Cutting Runtime Architecture

Every workload should traverse common enterprise services. The runtime path below is the reference: identity fronts everything, policy is evaluated centrally, data controls and encryption sit behind the application, and every layer emits sovereignty evidence.

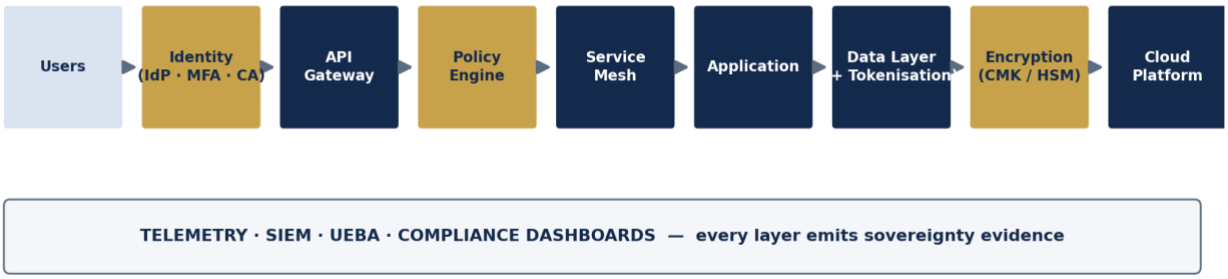


Figure — Cross-cutting enterprise services: every workload traverses common, sovereignty-enforcing controls

Figure 2 — Cross-cutting enterprise services: the reference runtime path every workload traverses.

5.1 Shared service obligations

Shared service	Sovereignty function	Owned by
Enterprise IdP + Conditional Access	Authenticates and risk-scores every request; enforces AU-only administration policies for Critical tier	Identity platform team
API Gateway	Terminates external trust; enforces schema, quota and data-classification headers	Integration platform team
Policy Engine (PDP)	Central authorisation decisions (e.g., OPA/Cedar-style); jurisdiction- and tier-aware	Platform engineering
Service Mesh	mTLS, workload identity, egress control (blocks unsanctioned cross-region calls)	Platform engineering
Tokenisation & DLP services	Substitutes high-value identifiers; detects and blocks exfiltration	Data platform / security engineering
Key Management (KMS/HSM)	CMK/BYOK/HYOK per tier; rotation; crypto-agility	Security engineering
Telemetry & SIEM	Collects control evidence; UEBA over privileged activity; feeds compliance dashboards	Security operations

6. The Seven Sovereignty Pillars

Each pillar is specified as: the question it answers, control objectives with stable identifiers (ADSRA-XX-nn), a reference pattern, indicative technology mappings, and the KRIs that evidence it. Technology mappings are indicative examples current at the time of writing, not endorsements; validate service capabilities and regions before design commitment.



Figure — The seven ADSRA sovereignty pillars, each framed by the question an executive must be able to answer

Figure 3 — The seven ADSRA pillars and the executive question each answers.

6.1 Pillar 1 — Data Sovereignty

Key question: *Who can legally compel access to our information?*

Control objectives

ID	Control objective
ADSRA-DS-01	All data assets carry a sovereignty tier (Section 2.2) recorded in the enterprise data catalogue, with a named information owner.
ADSRA-DS-02	High/Critical data is stored and processed in Australian regions; any cross-border transfer is assessed against APP 8 and recorded with a lawful basis.
ADSRA-DS-03	Critical identifiers (payment credentials, health identifiers) are tokenised at the boundary; raw values never enter analytical or AI estates.
ADSRA-DS-04	DLP policies enforce tier-appropriate egress controls across email, endpoints, SaaS and cloud storage.
ADSRA-DS-05	Privacy Impact Assessments are embedded in the delivery lifecycle for High/Critical changes, including AI use cases.
ADSRA-DS-06	Data lifecycle (retention, minimisation, deletion) is automated and evidenced per tier.

Reference pattern

Classification-driven landing zones: the data catalogue is the source of truth for tier; infrastructure-as-code consumes tier tags to bind residency, encryption and DLP policy at provision time. A retailer, for example, runs

its product catalogue globally on a CDN (Low) while customer profiles and loyalty behaviour (High) are pinned to Australian regions with customer-managed keys, and payment credentials (Critical) are tokenised with HSM-backed keys.

Indicative technology mapping

Capability	AWS	Azure / M365	Google Cloud / other
Classification & catalogue	Glue Data Catalog + Lake Formation tags	Microsoft Purview (labels, catalogue)	Dataplex / Data Catalog
Residency enforcement	SCPs + Region deny-lists	Azure Policy allowed-locations	Org Policy resource locations
Tokenisation	Payment Cryptography / partner vaults	Purview + partner tokenisation	DLP tokenisation, partner vaults
DLP	Macie + endpoint/CASB	Purview DLP + Defender for Cloud Apps	Cloud DLP + CASB

Key risk indicators

- % of data assets with an assigned tier and owner (target: 100% of High/Critical)
- Count of unassessed cross-border transfers detected per quarter (target: 0)
- % of Critical identifiers tokenised at boundary (target: 100%)

> **Industry note.** Healthcare: My Health Record information must be held and processed in Australia [R8] — treat connected estates as Critical by default. Retail: loyalty behavioural data is High, not Medium; it is the primary tort exposure after payment data. [Position]

6.2 Pillar 2 — Identity Sovereignty

Key question: *Who is acting, from where, and with what privilege?*

Control objectives

ID	Control objective
ADSRA-ID-01	A single enterprise IdP (Australian-controlled tenancy) fronts all workforce and workload identity; federation is governed and inventoried.
ADSRA-ID-02	Phishing-resistant MFA for all users; conditional access evaluates user, device, location, and risk score on every request (Zero Trust).
ADSRA-ID-03	Standing privilege is eliminated for Critical systems: just-in-time elevation via PIM/PAM with approval and session recording.
ADSRA-ID-04	Identity governance: automated joiner/mover/leaver, quarterly access recertification for High/Critical scopes.
ADSRA-ID-05	Workload identities (service principals, SPIFFE-style) are inventoried, short-lived and least-privileged.

Reference pattern

Every request answers: who, what, why, when, from where, at what risk score — replacing the legacy notion of a trusted network. For Critical-tier administration, conditional access additionally enforces jurisdiction (Australian location and managed device) before elevation is granted.

Indicative technology mapping

Capability	AWS	Azure / M365	Google Cloud / other
Enterprise IdP / CA	IAM Identity Center (+ external IdP)	Entra ID + Conditional Access	Cloud Identity + Context-Aware Access
Privileged access	IAM + partner PAM	Entra PIM + partner PAM	PAM partners
Identity governance	Partner IGA	Entra ID Governance	Partner IGA
Session recording	Systems Manager Session Manager	Azure Bastion + partner	IAP + partner

Key risk indicators

- % privileged elevations that are just-in-time (target: 100% for Critical)
- % privileged sessions on Critical systems recorded (target: 100%)
- Mean age of unreviewed High/Critical entitlements (target: < 90 days)

> **Industry note.** Banking: SOCI and CPS 234 both anticipate MFA, least privilege and monitoring of privileged activity; identity KRIs translate directly into CPS 234 control-assurance evidence.

6.3 Pillar 3 — Cryptographic Sovereignty

Key question: *Who controls the keys that control trust?*

Control objectives

ID	Control objective
ADSRA-CR-01	High-tier data uses customer-managed keys (CMK); Critical-tier uses HSM-backed CMK, BYOK or HYOK per risk assessment.
ADSRA-CR-02	Client-side (application-layer) encryption is applied where the threat model includes provider compulsion for Critical assets.
ADSRA-CR-03	Key custody, rotation, dual control and split knowledge are documented and evidenced; rotation is automated.
ADSRA-CR-04	Crypto-agility: algorithms and key hierarchies are abstracted so post-quantum migration is a configuration program, not a rebuild.

Reference pattern

Encryption is the last defence against jurisdictional uncertainty — but only if the enterprise, not the provider, controls the keys. The pattern is a tiered key hierarchy: provider-managed keys for Low, CMK for Medium/High, HSM-backed CMK or hold-your-own-key for Critical, with client-side encryption for the narrow set of assets whose threat model includes lawful compulsion of the provider. [Position: HYOK and client-side encryption break some native cloud features; apply them surgically, not universally.]

Indicative technology mapping

Capability	AWS	Azure / M365	Google Cloud / other
Key management	KMS (+ External Key Store)	Key Vault / Managed HSM	Cloud KMS (+ EKM)
Dedicated HSM	CloudHSM	Managed HSM / Dedicated HSM	Cloud HSM
Client-side encryption	Encryption SDK	Always Encrypted / SDKs	Tink / client libraries
Certificate & secrets	ACM / Secrets Manager	Key Vault	Certificate Authority Service / Secret Manager

Key risk indicators

- % High/Critical data encrypted under CMK or better (target: 100%)
- Keys within rotation policy (target: 100%; alert at T-30 days)
- % Critical assets with documented key-custody model (target: 100%)

6.4 Pillar 4 — Operational Sovereignty

Key question: *Who administers production — and from which jurisdiction?*

Control objectives

ID	Control objective
ADSRA-OP-01	Production administration of Critical systems is performed by personnel operating from Australia, under Australian legal employment or equivalent contractual control.
ADSRA-OP-02	An Australian SOC (in-house or sovereign partner) monitors Critical estates; incident response runbooks nominate Australian responders and legal counsel.
ADSRA-OP-03	Administrative separation: provider support access to Critical workloads requires explicit, logged, time-boxed enterprise approval (e.g., lockbox-style workflows).
ADSRA-OP-04	Break-glass accounts are jurisdiction-aware, sealed, alarmed and tested quarterly.
ADSRA-OP-05	Exit and substitution plans for material providers — including AI model and platform providers — are documented and tested to CPS 230 expectations.

Reference pattern

Operational sovereignty is the fastest-growing discipline in this domain because regulators have shifted from asking where data lives to asking who can act on it. The reference pattern: privileged access workstations, just-in-time elevation, session recording, provider-access approval workflows, and evidence flowing to the observability pillar.

Indicative technology mapping

Capability	AWS	Azure / M365	Google Cloud / other
Provider access control	n/a (support access policies)	Customer Lockbox (M365/Azure)	Access Approval / Access Transparency

Capability	AWS	Azure / M365	Google Cloud / other
Session recording	SSM Session Manager	Bastion + PAM partners	IAP + PAM partners
SOC tooling	Security Hub / partner SIEM	Microsoft Sentinel	Chronicle / partner SIEM
Sovereign operations options	AWS local zones/partners	Azure Australia regions + sovereign partners	GCP AU regions + sovereign partners

Key risk indicators

- % privileged sessions on Critical systems administered from Australia (target: 100%)
- % provider-access requests to Critical workloads explicitly approved (target: 100%)
- Exit-plan test recency for material providers (target: ≤ 12 months)

> **Industry note.** Financial services: CPS 230 requires notification within 24 hours of a disruption to a critical operation outside tolerance [R1]; that clock is only meetable when detection, decision rights and responders are local and rehearsed. [Position]

6.5 Pillar 5 — AI Sovereignty

Key question: *Where do prompts, embeddings, inference and training occur — and who governs the outputs?*

Control objectives

ID	Control objective
ADSRA-AI-01	All generative AI traffic traverses an enterprise LLM gateway; direct application-to-model integrations are prohibited for High/Critical data.
ADSRA-AI-02	A model registry records approved models, versions, hosting regions, licences, evaluation results and each model's provider and material sub-processors (the AI supply-chain map); it doubles as the enterprise AI inventory, and deployment is only from the registry.
ADSRA-AI-03	Prompt and retrieval pipelines apply PII detection/redaction and policy checks before any model call; High/Critical inference executes in Australian regions.
ADSRA-AI-04	RAG corpora and vector stores inherit the tier of their source data, including residency and access controls; embeddings of Critical data are treated as Critical.
ADSRA-AI-05	Enterprise data is excluded from provider training by contract and configuration; fine-tuning uses governed, tiered datasets only.
ADSRA-AI-06	Outputs to customers or decisions significantly affecting individuals are validated, logged, and disclosed per the ADM transparency obligations effective 10 Dec 2026 [R3, R17]. Human review does not by itself take a use case out of ADM scope — the OAIC says a decision may be in scope even where the program output is subject to human review [R17]; a disclosure register feeds the privacy-policy disclosure.
ADSRA-AI-07	Agentic systems are inventoried and operate under scoped tool permissions, budget/turn limits, controls for prompt injection and tool misuse, and human oversight proportionate to impact.

Reference pattern

The model is only one component. The reference flow places a prompt gateway, policy engine, PII detection, governed RAG, model registry and response validation around the model, with every hop evidenced in an immutable audit trail — the LLM never talks directly to users or raw data stores.

Decision assurance (v0.2 addition). Beyond residency of prompts and inference, the ADSRA-AI control objectives now cover the assurance of AI-influenced decisions: an algorithmic and stakeholder impact assessment before deployment; explainability and a documented contestability path for decisions that significantly affect individuals; human oversight and accountability for outputs; and bias and fairness testing. These operationalise Australia's AI Ethics Principles (DISR 2019) and the National framework for the assurance of AI in government [R13], and are manageable under AS ISO/IEC 42001 [R11]. For public-sector and public-adjacent workloads the framework applies directly; for regulated private-sector entities it is a benchmark that the 10 December 2026 ADM-transparency obligation [R3] turns, in part, into a hard constraint. For Commonwealth agencies the DTA's Policy for the responsible use of AI in government v2.0 [R18] makes use-case impact assessment mandatory by 15 December 2026.

Prudential AI expectations (v0.3 addition). APRA's letter on AI (30 April 2026) [R14] asks regulated entities for an AI inventory, human involvement in high-risk decisions, controls for AI-specific threats, a mapped AI supply chain with contractual transparency and audit rights, credible exit and substitution strategies, and continuous monitoring proportionate to criticality. ADSRA already specifies each: inventory → ADSRA-AI-02; human involvement → AI-06, AI-07; AI-specific threats → AI-03, AI-07, DS-04, OB-02; supply-chain map, transparency and audit rights → AI-02, AI-05, OP-03; concentration and exit → OP-05; continuous monitoring and board visibility → OB-03, OB-04 and §11.2. Two expectations are capabilities rather than controls — staff training and second-line skills to assess probabilistic models and autonomous workflows — and are deliberately not turned into control objectives here. This mapping validates the design direction; it does not make ADSRA a regulatory requirement, and the letter neither mentions sovereignty nor cites CPS 230 or CPS 234. [Position]

Sovereign model supply [Position]. The model registry may include Australian-owned sovereign foundational models served from onshore compute as an option for High/Critical workloads where in-region access to global frontier models lags. Building sovereign models and infrastructure is a supply-side effort; ADSRA is the demand-side complement that governs and measures how any model — sovereign-built or global — is consumed. Treat provider capability claims as market context to be verified, not as cited evidence. Government policy is moving on the supply side too: the data-centre expectations [R16] name national security and data sovereignty (expectation 1).

Indicative technology mapping

Capability	AWS	Azure / M365	Google Cloud / other
Managed model hosting (AU)	Bedrock (AU regions/CRIS)	Azure OpenAI (Australia East)	Vertex AI (AU regions)
Gateway & guardrails	Bedrock Guardrails + API GW	APIM GenAI gateway + Content Safety	Apigee + Model Armor
Vector / RAG	OpenSearch / Kendra	AI Search	Vertex AI Search / AlloyDB pgvector
AI observability	CloudWatch + partner (e.g., Datadog LLM Observability)	Azure Monitor + partner	Cloud Monitoring + partner

Key risk indicators

- % AI inference on High/Critical data executed in-region via the gateway (target: 100%)
- % of AI tools and use cases held in the registry/inventory (target: 100%)
- % production AI use cases with registry-pinned model versions (target: 100%)
- PII redaction efficacy on sampled prompts (target: ≥ 99%, measured monthly)

- % AI decisions in ADM scope with transparency disclosures ready (target: 100% before 10 Dec 2026)

% of ADM-scope AI use cases with a completed algorithmic/impact assessment and a documented contestability path (target: 100%)

> **Industry note.** Retail example: an AI pricing assistant for merchandising teams routes via prompt gateway → policy engine → PII detection → enterprise RAG → approved AU-region model → response filter → audit log. Healthcare: clinical-adjacent AI inherits Critical tier; inference outside Australia is a design non-starter where My Health Record data is in scope [R8].

6.6 Pillar 6 — Governance Sovereignty

Key question: *Is compliance enforced by the platform, or by a policy document?*

Control objectives

ID	Control objective
ADSRA-GV-01	Sovereignty policies are expressed as code (e.g., Azure Policy, AWS SCPs, GCP Org Policy, OPA) and applied at management-group/organisation scope.
ADSRA-GV-02	CI/CD pipelines validate infrastructure-as-code against tier policies pre-deployment; non-compliant deployments fail closed for High/Critical.
ADSRA-GV-03	Guardrail exceptions are time-boxed, risk-accepted by the accountable executive, and auto-expire.
ADSRA-GV-04	Compliance posture is continuously assessed (CSPM) and mapped to the obligation matrix in Section 3.

Reference pattern

Governance sovereignty converts 'developers should…' into 'the platform enforces…'. Every deployment inherits compliance from the landing zone; drift is detected and remediated automatically; exceptions are visible liabilities, not silent debt.

AI management alignment (v0.2 addition). ADSRA-GV control objectives align to AS ISO/IEC 42001:2023 (AI management system) and AS ISO/IEC 23894:2023 (AI risk management) [R11], and to the cornerstones of the National framework for the assurance of AI in government — governance, data governance, a risk-based approach, standards and procurement [R13]. Governance sovereignty is where the enterprise evidences that AI assurance is enforced by the platform, not asserted in a policy document.

Indicative technology mapping

Capability	AWS	Azure / M365	Google Cloud / other
Policy-as-code	SCPs + Config Rules	Azure Policy + Initiatives	Org Policy + Config Validator
Pipeline gates	CodePipeline + cfn-guard/Checkov	GitHub/ADO + PSRule/Checkov	Cloud Build + Checkov/OPA
CSPM / posture	Security Hub	Defender for Cloud	Security Command Center
Landing zones	Control Tower	Landing Zones (CAF)	Fabric/Foundation blueprints

Key risk indicators

- % deployments passing policy gates first time (target: ≥ 90%; investigate both tails)
- Open guardrail exceptions on Critical tier (target: trend to 0; none > 90 days)
- Mean time to remediate policy drift (target: < 24 hours for Critical)

6.7 Pillar 7 — Observability Sovereignty

Key question: *Can we prove, audit and continuously measure sovereignty?*

Control objectives

ID	Control objective
ADSRA-OB-01	All sovereignty controls emit telemetry to central logging; High/Critical audit trails are immutable (WORM/retention-locked).
ADSRA-OB-02	SIEM and UEBA cover privileged activity, cross-region data movement, and AI gateway traffic.
ADSRA-OB-03	AI observability captures prompts, retrievals, model versions, token/cost, latency and jurisdiction of inference per request (subject to privacy minimisation).
ADSRA-OB-04	Sovereignty KRIs (Section 11) are computed from telemetry — not attestations — and reported quarterly to the Architecture Board and Risk Committee.
ADSRA-OB-05	Regulatory reporting artefacts (e.g., CPS 230 incident notifications, OAIC NDB assessments, ASD ransomware-payment reports) are producible from evidence within notification windows.

Reference pattern

Observability is the currently underdeveloped pillar and, in the author's assessment, the highest-leverage investment: it converts sovereignty from an asserted property into a measured one, and it is the substrate for maturity Level 6 (autonomous assurance). [Position]

Indicative technology mapping

Capability	AWS	Azure / M365	Google Cloud / other
Central logging / audit	CloudTrail + S3 Object Lock	Azure Monitor + immutable storage	Cloud Audit Logs + Bucket Lock
SIEM / UEBA	Partner SIEM (Splunk/Datadog)	Microsoft Sentinel	Chronicle
AI observability	Partner LLM observability (e.g., Datadog)	Azure AI Foundry tracing + partner	Vertex + partner
Dashboards	QuickSight/Grafana	Power BI	Looker/Grafana

Key risk indicators

- % sovereignty controls with live telemetry (target: 100% for Critical tier)
- Mean time to detect cross-jurisdiction data movement (target: < 1 hour for Critical)

- % KRIs computed from telemetry vs attestation (target: > 80%)

7. AI Sovereignty Reference Flow (Detailed)

Figure 4 details the Pillar 5 reference flow. Design intent: no user, application or agent ever addresses a model directly; every hop is policy-controlled; every request is reconstructable from the audit trail — prompt, retrieval set, model version, jurisdiction, output and validation outcome.

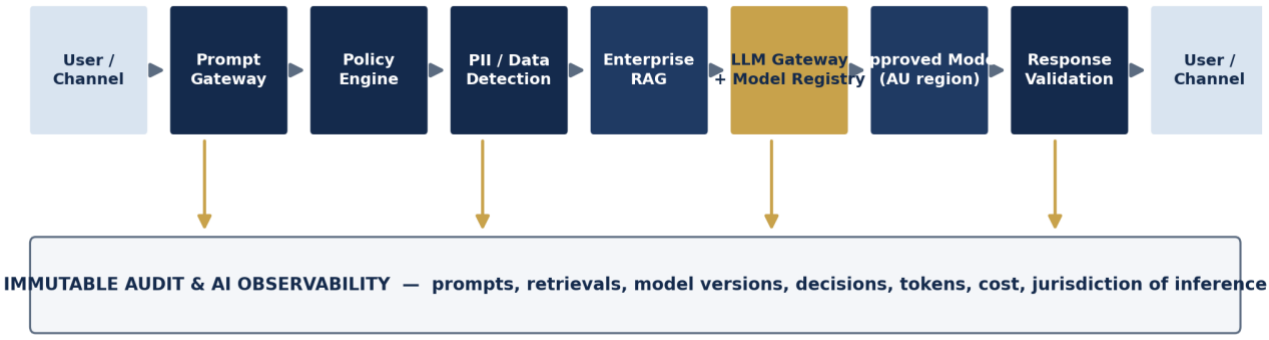


Figure — AI sovereignty reference flow: the model is only one component; every hop is policy-controlled and evidenced

Figure 4 — AI sovereignty reference flow: every hop policy-controlled and evidenced.

7.1 Worked example — retail AI pricing assistant

A merchandising analyst asks for a price-elasticity recommendation. The prompt gateway authenticates the analyst and stamps the request with data-classification context. The policy engine confirms the use case is registered and the analyst is entitled. PII detection redacts any customer identifiers pasted into the prompt. Enterprise RAG retrieves only from the governed pricing corpus (Medium tier). The LLM gateway routes to the registry-pinned model in an Australian region. The response filter checks for leakage and policy violations before returning the answer. The audit log records the full trace. Elapsed overhead versus a direct model call: tens of milliseconds; governance value: the difference between an approvable and an unapprovable use case. [Position]

7.2 Worked example — bank customer-service copilot

Customer context (Critical: identity and account data) is tokenised before retrieval; the copilot's RAG corpus is the governed knowledge base, not raw core-banking records. Inference is pinned to an Australian region; outputs that constitute decisions with significant effect (e.g., hardship eligibility guidance) are flagged into the ADM disclosure register that feeds the privacy-policy disclosure due 10 Dec 2026 [R3, R17]; human review in the loop improves the outcome but does not by itself remove the disclosure duty [R17].

8. The Reference Capability Model

Twenty enterprise capabilities operationalise the pillars. Each has a stable ID, an accountable owner archetype, a target maturity for a regulated enterprise, and the control objectives it realises.

ID	Domain	Capability	Owner archetype	Target maturity	Realises
ADSRA-C01	Data	Data Classification	CDO / Data Governance	L4	DS-01
ADSRA-C02	Data	Data Residency Management	Cloud Platform	L4	DS-02
ADSRA-C03	Data	Privacy Engineering	Privacy / CDO	L4	DS-03..06
ADSRA-C04	Identity	Identity & Access Management	CISO / Identity	L4	ID-01, ID-02
ADSRA-C05	Identity	Privileged Access Management	CISO	L5	ID-03
ADSRA-C06	Identity	Federation & Workload Identity	Identity Platform	L4	ID-01, ID-05
ADSRA-C07	Crypto	Key Management	Security Engineering	L4	CR-01, CR-03
ADSRA-C08	Crypto	HSM Services	Security Engineering	L4	CR-01, CR-02
ADSRA-C09	Operations	Australian Operations	CIO / Ops	L4	OP-01, OP-03
ADSRA-C10	Operations	Incident Response (AU)	CISO / SOC	L4	OP-02, OP-04
ADSRA-C11	Governance	Policy-as-Code	Platform Engineering	L5	GV-01, GV-02
ADSRA-C12	Governance	Compliance Automation	Risk / Platform	L4	GV-03, GV-04
ADSRA-C13	AI	AI Gateway	AI Platform	L4	AI-01, AI-03
ADSRA-C14	AI	Prompt Management	AI Platform	L4	AI-03
ADSRA-C15	AI	RAG Governance	AI Platform / CDO	L4	AI-04
ADSRA-C16	AI	Model Registry & Evaluation	AI Platform	L5	AI-02, AI-05, AI-06
ADSRA-C17	Observability	Sovereignty Telemetry	SecOps / Platform	L5	OB-01, OB-02
ADSRA-C18	Observability	Immutable Audit	SecOps	L4	OB-01, OB-05
ADSRA-C19	Observability	AI Monitoring & Observability	AI Platform / SecOps	L5	OB-03
ADSRA-C20	Risk	Continuous Assurance	CRO / Architecture Board	L5→L6	OB-04, GV-04

Using the model. Fund capabilities, not projects: each capability carries a backlog, an owner and KRIs. A maturity heatmap over these 20 capabilities is the recommended quarterly Architecture Board artefact.

9. The ADSRA Maturity Model

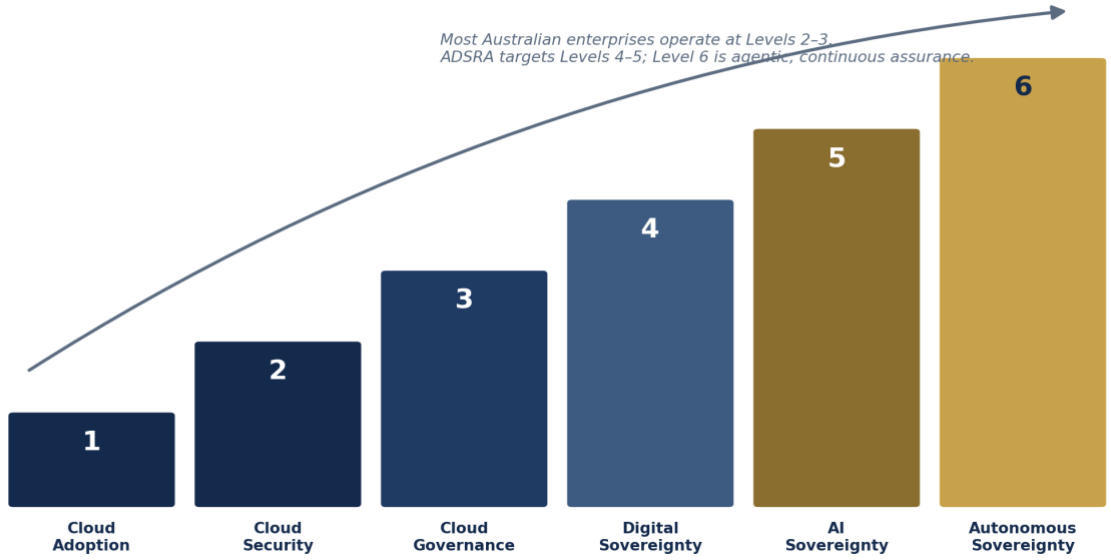


Figure 5 — Six maturity levels, from cloud adoption to autonomous sovereignty.

Level	Name	Defining characteristics	Assessment evidence
1	Cloud Adoption	Workloads migrating; controls inherited ad hoc from providers	Cloud spend exists; no tiering; no sovereignty KRIs
2	Cloud Security	Baseline hardening (Essential Eight aligned); perimeter and identity basics	ISM/E8 assessments; MFA coverage; SIEM ingesting cloud logs
3	Cloud Governance	Landing zones, tagging, cost and policy governance emerging	Policy-as-code coverage; exception registers; CSPM scores
4	Digital Sovereignty	Tiered classification drives residency, CMK, AU operations for Critical; obligations mapped to controls	≥90% High/Critical tiered; CMK coverage; AU-ops evidence; obligation matrix live
5	AI Sovereignty	All AI via gateway + registry; RAG governance; AI observability; ADM-transparency readiness	Gateway coverage; registry adoption; prompt-audit sampling; ADM register
6	Autonomous Sovereignty	Agentic continuous assurance: platform detects and remediates sovereignty drift (jurisdiction moves, key expiry, offshore inference, anomalous admin locations)	Closed-loop remediation metrics; assurance agents in production with human oversight

Level 6 is the model's genuinely new contribution: sovereignty ceases to be an audit finding and becomes a continuously computed property of the platform. It is deliberately aspirational — pilots, not production, are the realistic target inside the 24-month planning window for most enterprises. [Position]

> **Targets re-baselined (v0.3).** Level 4 for Critical and High estates within roughly 15 months and Level 5 within roughly 24 months, compressed from 36. The compression is author judgement driven by dates that arrived early — ADM transparency on 10 Dec 2026, APRA's AI expectations already issued, a national AI framework expected in legislation in early 2027, the DTA impact-assessment date of 15 Dec 2026 for agencies — and by the CIRMP

> implementation windows (10 Jun 2027, 10 Jun 2028) for the asset classes covered. It is not itself a regulatory requirement. [Position]

10. Industry Blueprints

10.1 Banking

- Anchor obligations: CPS 230 (critical operations, tolerance levels, MSPs) [R1]; CPS 234 [R2]; SOCI financial services sector [R5]; Privacy Act [R3].
- Critical-tier assets: payment systems, core banking ledgers, customer identity, fraud models.
- Signature patterns: sovereignty tiers mapped 1:1 to the CPS 230 critical-operations register; AU SOC with rehearsed 24-hour notification path; exit/substitution plans tested against hyperscaler and core-vendor scenarios; AI copilots on governed knowledge bases only. AI layer (APRA letter [R14]): AI inventory held in the model registry, AI supply chain mapped incl. fourth parties, exit and substitution plans for AI providers, and human involvement in high-risk decisions.
- Worked example: customer-service copilot (Section 7.2).

10.2 Financial services and superannuation

- Anchor obligations: CPS 230 MSP register incl. fourth parties [R1]; member data under Privacy Act tiered penalties [R3]; APRA's AI letter for insurers and superannuation trustees [R14].
- Signature patterns: provider-concentration KRIs to the Risk Committee; administrator (often outsourced) operations brought under ADSRA-OP controls contractually; advice/interaction AI logged for ADM-transparency scope from Dec 2026.

10.3 Retail

- Anchor obligations: Privacy Act incl. statutory tort [R3]; PCI DSS (contractual); SOCI applies to food & grocery among covered sectors [R5].
- Tiering example (national retailer): catalogue ★, pricing ★★, loyalty behaviour ★★★ (High), customer profiles ★★★, payment cards ★★★★ (Critical).
- Signature patterns: checkout in Azure Australia East with CMK, tokenised payments and local SOC; catalogue on global CDN with no sovereignty premium; AI pricing assistant per Section 7.1; personalisation models reviewed for ADM-transparency scope.

10.4 Healthcare

- Anchor obligations: My Health Records Act AU data-handling requirements [R8]; Privacy Act sensitive-information provisions [R3]; SOCI healthcare sector [R5].
- Signature patterns: connected clinical estates Critical by default; client-side encryption for identifiable clinical data where feasible; AI (clinical documentation, triage assist) restricted to AU-region inference with clinician-in-the-loop validation; corporate estate (HR in M365) governed via sensitivity labels, DLP, conditional access and insider-risk tooling.

Public-sector reach (v0.2 addition). The National framework for the assurance of AI in government [R13] binds Commonwealth, state and territory agencies directly. The DTA's policy v2.0 [R18] adds a 15 December 2026 date for Commonwealth agencies' use-case impact assessments. That makes utilities and education — both heavily public or public-adjacent — the highest-value blueprints in a regulation-led estate, which is why they are expanded in full below. They remain open for peer-review contribution (see Section 14, OQ-4). [Position]

10.5 Utilities

Anchor obligations: Security of Critical Infrastructure Act 2018 — energy, water, gas and other covered sectors — with Critical Infrastructure Risk Management Program duties and mandatory incident reporting [R5] — uplifted for electricity, gas and water assets by the Enhanced CIRMP Rules (commenced 10 June 2026; implementation by 10 June 2027 or 10 June 2028 depending on the requirement) [R19], with Tranche 2 reforms (managed-service-provider, supply-chain and AI-related incident duties) proposed but not law; ASD/ACSC Information Security Manual and Essential Eight applied across the OT/IT boundary [R6]; Privacy Act 1988 for customer connection and metering data [R3]; and, where the entity is government-owned or a public agency, the National framework for the assurance of AI in government [R13]. Defence-in-depth OT zoning frames the control baseline. [Position]

Critical-tier assets: OT/SCADA control systems and field telemetry; wholesale market bidding, dispatch and settlement data; customer connection, metering and consumption data; and network-asset and outage models.

Tiering example (distribution utility): public network maps and tariffs ★; aggregated demand analytics ★★; customer connection and metering data ★★★ (High); market bidding and settlement data ★★★ (High); OT/SCADA control and safety systems ★★★★ (Critical).

Signature patterns: hard OT/IT segmentation with Australian-based operations and a local SOC; sovereignty tiers mapped to the SOCI critical-infrastructure register so tolerance and reporting duties inherit automatically; customer-managed keys for market and customer data; jurisdiction-aware break-glass for any remote OT administration; exit and substitution plans tested for control-system and cloud-analytics vendors.

AI assurance: forecasting, outage-prediction and asset-failure models route through the Pillar 5 gateway with an algorithmic/impact assessment, model-registry pinning and human oversight for any decision affecting supply or safety; no model is permitted direct control of OT actuation. Aligned to the National AI assurance framework [R13] and AS ISO/IEC 42001 [R11].

Worked example: an outage-prediction assistant queries network telemetry and weather feeds through the Section 7 reference flow — prompt gateway → policy engine → governed retrieval over in-region operational data → AU-region inference → response validation — producing recommendations advisory to a human control-room operator, never actuating plant directly. [Position]

10.6 Education

Anchor obligations: Privacy Act 1988, including student personal and sensitive information [R3]; state and territory AI assurance frameworks (e.g. the NSW AI Assurance Framework, 2022) and, for public institutions, the National framework for the assurance of AI in government [R13] and, for Commonwealth agencies, the DTA policy v2.0 [R18]; child-safety and online-safety obligations where learners are minors, including the OAIC's draft Children's Online Privacy Code (must be registered by 10 December 2026) [R21]; and export-control/IP considerations for sensitive research. [Position]

Critical-tier assets: student identity and records; assessment and examination data; wellbeing and disciplinary records; and research data carrying IP, commercial or export-control sensitivity.

Tiering example (university / school system): public course catalogue ★; learning materials ★★; student records and identity ★★★ (High); assessment and wellbeing data ★★★ (High); minors' personal data and sensitive research ★★★★ (Critical).

Signature patterns: student and assessment data resident in Australia with customer-managed keys; sensitivity labels and DLP across the M365/Google education estate; conditional access and least privilege for staff; strict tiering of minors' data; and tested exit plans for the LMS and analytics stack.

AI assurance: tutoring, marking and admissions copilots run on governed RAG with human oversight, a documented contestability path for any automated assessment or eligibility decision, bias/fairness testing across cohorts, and disclosure aligned to the ADM-transparency obligation [R3] and the National AI assurance framework [R13]. Automated marking never issues a final grade without human ratification. [Position]

Worked example: a marking-assistant copilot drafts feedback and a provisional score via the Section 7 reference flow — PII detection strips identifiers, retrieval is limited to the governed rubric corpus, inference runs in-region — and an educator reviews, adjusts and ratifies before any grade reaches the student, whose right to contest is recorded. [Position]

11. Metrics, Assurance and Implementation

11.1 KRI catalogue (Board-level subset)

KRI	Pillar	Target	Cadence
% High/Critical data under CMK or better	Crypto	100%	Monthly
% privileged sessions on Critical systems from AU (recorded)	Operations	100%	Monthly
% AI inference on High/Critical data in-region via gateway	AI	100%	Monthly
% deployments passing policy gates first time	Governance	≥ 90%	Per release / monthly
Mean time to detect cross-jurisdiction data movement	Observability	< 1 hr (Critical)	Quarterly test
% material providers with tested exit plans ≤ 12 months old	Operations	100%	Quarterly
% ADM-scope AI decisions with transparency disclosures ready	AI / Data	100% by 10 Dec 2026	Monthly to deadline
% AI tools and use cases held in the registry/inventory	AI	100%	Monthly

11.2 Operating model

- Accountable executive owner for digital sovereignty (typically CIO or CISO), with the Architecture Board as design authority and the Risk Committee receiving KRIs quarterly.
- A Sovereignty Community of Practice connects platform, data, AI, security and privacy engineering — the pattern library and exception learnings live here.
- Every High/Critical solution design names its tier, inherited controls and exceptions on one page — the 'sovereignty passport' — reviewed at design authority. [Position]

11.3 Three-horizon roadmap

Horizon	Focus	Exit criteria
H1 · 0–6 months	Foundations: tier the High/Critical estate; baseline the 20 capabilities; stand up LLM gateway + model registry (the AI inventory) for all AI pilots; sovereignty KRIs to Risk Committee. Regulatory sprint to 10 Dec 2026: triage AI use cases against the APP 1.7 test and draft ADM disclosures	Tiering ≥ 90% of High/Critical; first KRI report delivered; no untracked AI integrations; ADM disclosures published by 10 Dec 2026 where in scope
H2 · 6–15 months	Enforcement: CMK/HSM for Critical; policy-as-code gates in all pipelines; AU operations and session recording for critical ops; RAG governance and PII detection in production; AI supply chain mapped; provider (incl. AI provider) exit plans tested	Level 4 assessed across Data/Identity/Crypto/Ops/Governance for Critical and High estates (≈15 months); exit strategies tested for material AI providers

Horizon	Focus	Exit criteria
H3 · 15–24 months	Assurance: continuous sovereignty assurance pilots (Level 5→6); agentic compliance monitoring; publish and iterate the reference architecture	Level 5 assessed for AI and Observability (≈24 months); Level 6 pilots under human oversight; at least one closed-loop remediation pattern piloted [Position]

11.4 Anti-patterns

- Sovereignty theatre: residency without key custody or operational control — satisfies a slide, not a subpoena. [Position]
- Over-classification: defaulting everything to Critical destroys the cost logic and delivery velocity that make the scheme sustainable.
- Gateway bypass: 'temporary' direct model integrations for pilots that become permanent, invisible AI estate.
- Attestation-based KRIs: metrics from surveys rather than telemetry — see ADSRA-OB-04.

12. Evidence Register (Claims → Sources)

For peer review: material factual claims and their anchors. [Position] items are the author's judgement and are argued, not cited.

v0.2 additions. Claim: Australian governments maintain a published, principles-based AI-assurance expectation → [R13] National framework for the assurance of AI in government (v1.0, 21 June 2024), based on Australia's AI Ethics Principles (DISR 2019). Claim: recognised AI management and risk standards exist to anchor governance → [R11] AS ISO/IEC 42001:2023, AS ISO/IEC 23894:2023 and AS ISO/IEC 38507:2022. [Position]: Australian-owned sovereign model and compute options are emerging that may narrow the in-region frontier-availability gap — market context, not a cited obligation; provider claims to be verified before reliance.
v0.3 additions. Primary pages read in full: APRA CPS 230 and its April 2026 amendments, the APRA AI letter, the Prime Minister's speech of 15 July 2026, and the OAIC release page for the ADM transparency resources (published 30 September 2026; obligation commences 10 December 2026). Re-verified at primary source on 16 October 2026 (v0.3 release gate): the OAIC APP Guidelines Chapter 1 v2.0, the DISR data-centre expectations, the DTA AI policy v2.0 and impact-assessment dates, the Enhanced CIRMP Rules instrument (F2026L00701), the Joint Select Committee page, the Children's Code page, ransomware-payment reporting (Home Affairs; ASD), the AU–US CLOUD Act Agreement (Attorney-General's Department), the Hosting Certification Framework page and Privacy Act s 13G. Three wording corrections followed: s 13G covers a serious interference (repeated conduct is a seriousness factor, not a separate limb); the Children's Code must be registered by 10 December 2026 (a statutory deadline, not a target); the ransomware threshold is annual turnover of $3m or more. The OAIC guidance itself states that human review does not by itself take a decision out of APP 1.7 scope, so that reading is now cited [R17] rather than marked [Position]. Open, accepted by the author: the SOCI Tranche 2 measure count and closing date come from the consultation paper, which was not read in full; the Home Affairs consultation page confirms the proposals and that consultation has closed. [Position]: the 24-month Level 4–5 target is the author's judgement, argued not cited.

Claim in this document	Source
CPS 230 in force 1 Jul 2025; pre-existing MSP contracts by earlier of renewal or 1 Jul 2026; targeted amendments final 30 Apr 2026, effective 1 Jul 2026 (narrow relief for non-traditional providers; notification clocks unchanged)	R1 (APRA, incl. final targeted amendments)
CPS 230: notify APRA ≤ 24 hrs for disruption to a critical operation outside tolerance; ≤ 72 hrs for material operational risk incidents	R1 (CPS 230 paras 42, 33)
CPS 234 in force since 2019; 72-hour information-security incident notification	R2 (APRA)
Privacy amendment Act assent 10 Dec 2024; statutory tort commenced by Jun 2025; ADM transparency (APP 1.7–1.9) from 10 Dec 2026; OAIC final ADM guidance Sep 2026	R3, R17 (Act; OAIC; firm analyses)
Civil penalties up to the greater of $50m / 3× benefit obtained (or, if the benefit cannot be determined, 30% of adjusted turnover) for a serious interference with privacy (s 13G)	R4 (Privacy Act s 13G — primary, read 16 Oct 2026)
SOCI covers 11 sectors incl. financial services, healthcare, energy, data storage; CIRMP spans cyber, personnel, supply-chain, physical hazards	R5 (CISC)
Hosting Certification Framework: Certified Strategic / Assured; applies to new contracts from 30 Jun 2022	R7 (hostingcertification.gov.au)
My Health Record data must be held and processed in Australia	R8 (My Health Records Act 2012)
US CLOUD Act: production obligations regardless of data location	R9 (CLOUD Act 2018)

Claim in this document	Source
Voluntary AI Safety Standard (2024) superseded by Guidance for AI Adoption (Oct 2025); National AI Plan (Dec 2025) chose existing law; AI Safety Institute operational 2026 (advisory); mandatory-guardrail proposals not taken up	R10 (DISR/NAIC; legal analyses)
APRA AI letter 30 Apr 2026: expectations of boards and accountable executives (inventory, human involvement in high-risk decisions, AI-specific threat controls, AI supply-chain map, exit/substitution, continuous monitoring, second-line capability)	R14 (APRA — primary)
PM announcement 15 Jul 2026: mandatory Australian Standards for AI and Office of AI; legislation expected early 2027; defined so far for data centres and AI-training use of creative work; high-risk AI not mentioned in the speech	R15 (PM speech — primary)
Data-centre and AI infrastructure expectations published 23 Mar 2026; five expectations; expectation 1 includes national security and data sovereignty	R16 (DISR — primary, read 16 Oct 2026)
DTA AI policy v2.0 effective 15 Dec 2025; agencies implement use-case impact assessment by 15 Dec 2026; internal register and accountable owners	R18 (DTA — primary, read 16 Oct 2026)
Enhanced CIRMP Rules commenced 10 Jun 2026 for nine specified asset classes; 12- or 24-month implementation (10 Jun 2027 / 10 Jun 2028); 12-month items (s 6A) include foreign ownership, control or influence (FOCI) and offshore or remote access to critical components and business-critical data	R19 (Rules instrument F2026L00701 — primary, read 16 Oct 2026)
SOCI Tranche 2 reform proposals (21 measures); consultation closed 31 Jul 2026 — proposals only, not law	R19 (Home Affairs consultation page — primary, read 16 Oct 2026; measure count and closing date from the paper, not read in full — open, accepted by author)
Joint Select Committee on AI appointed 20 Aug 2026; terms include data sovereignty; final report due 30 Nov 2026	R20 (aph.gov.au — primary, read 16 Oct 2026)
Children's Online Privacy Code: exposure draft; must be registered by 10 Dec 2026 (statutory deadline; draft — not in force)	R21 (OAIC Code page — primary, read 16 Oct 2026)
Australia–US CLOUD Act Agreement in force 30 Jan 2024 (serious-crime data requests, both directions)	R22 (Attorney-General's Department — primary, read 16 Oct 2026)
Ransomware and cyber-extortion payment reporting to ASD within 72 hours from 30 May 2025 (entities with annual turnover of $3m or more; responsible entities for critical infrastructure assets)	R23 (Home Affairs; ASD — primary, read 16 Oct 2026)

13. References

[R1] Australian Prudential Regulation Authority, Prudential Standard CPS 230 Operational Risk Management (in force 1 July 2025; targeted amendments final 30 April 2026, effective 1 July 2026) and Prudential Practice Guide CPG 230. https://www.apra.gov.au/operational-risk-management

[R2] Australian Prudential Regulation Authority, Prudential Standard CPS 234 Information Security (2019). https://www.apra.gov.au

[R3] Privacy Act 1988 (Cth); Privacy and Other Legislation Amendment Act 2024 (Cth) (assent 10 December 2024). See also OAIC guidance on the statutory tort and APP 1.7–1.9 automated-decision transparency (effective 10 December 2026; OAIC final resources September 2026). https://www.oaic.gov.au

[R4] Privacy Legislation Amendment (Enforcement and Other Measures) Act 2022 (Cth) — penalty amounts; Privacy Act 1988 (Cth) s 13G as currently compiled — civil penalty for a serious interference with privacy (repeated or continuous conduct is a seriousness factor, s 13G(1B)(f)). https://www.legislation.gov.au/C2004A03712/latest/text

[R5] Security of Critical Infrastructure Act 2018 (Cth); Critical Infrastructure Risk Management Program Rules, incl. the Enhanced CIRMP Rules 2026 (commenced 10 June 2026). Cyber and Infrastructure Security Centre. https://www.cisc.gov.au

[R6] Australian Signals Directorate / Australian Cyber Security Centre, Information Security Manual and Essential Eight; Infosec Registered Assessors Program (IRAP). https://www.cyber.gov.au

[R7] Digital Transformation Agency / Department of Home Affairs, Hosting Certification Framework (March 2021; contract applicability from 30 June 2022; reform under way — new certification registrations paused from 3 November 2025). https://www.hostingcertification.gov.au

[R8] My Health Records Act 2012 (Cth) — Australian data-handling requirements for My Health Record information.

[R9] Clarifying Lawful Overseas Use of Data (CLOUD) Act, H.R. 4943, 115th Congress (2018) (US).

[R10] Department of Industry, Science and Resources / National AI Centre: Voluntary AI Safety Standard (2024); Guidance for AI Adoption (October 2025); National AI Plan (December 2025); Australian AI Safety Institute (operational 2026; advisory, not a regulator). https://www.industry.gov.au

[R11] ISO/IEC 42001:2023 Artificial intelligence — Management system; NIST AI Risk Management Framework 1.0 (2023). Related standards: AS ISO/IEC 23894:2023 (AI risk management) and AS ISO/IEC 38507:2022 (governance implications of the use of AI by organizations).

[R12] The Open Group, TOGAF Standard; SABSA Institute, SABSA framework; AWS Well-Architected Framework; Microsoft Azure Well-Architected Framework — positioning references.

[R13] Australian, state and territory governments, National framework for the assurance of artificial intelligence in government (Version 1.0, 21 June 2024). Based on Australia's AI Ethics Principles (DISR 2019). Published by the Australian Government (Data and Digital Ministers). Government-scoped; a benchmark for regulated private-sector entities.

[R14] Australian Prudential Regulation Authority, Letter to industry on artificial intelligence (AI), 30 April 2026. https://www.apra.gov.au/apra-letter-to-industry-on-artificial-intelligence-ai

[R15] Prime Minister of Australia, "AI in Australia's interests" (speech, University of Sydney, 15 July 2026). https://www.pm.gov.au/media/ai-australias-interests-0
[R16] Department of Industry, Science and Resources, Expectations of data centres and AI infrastructure developers (23 March 2026). https://www.industry.gov.au/publications/expectations-data-centres-and-ai-infrastructure-developers
[R17] Office of the Australian Information Commissioner, APP 1.7–1.9 Transparency Obligation fact sheet, flowchart and APP Guidelines Chapter 1 v2.0 (September 2026). https://www.oaic.gov.au/news/media-centre/new-resources-on-transparency-for-use-of-ai-and-automated-decision-making; https://www.oaic.gov.au/privacy/australian-privacy-principles/australian-privacy-principles-guidelines/chapter-1-app-1-open-and-transparent-management-of-personal-information
[R18] Digital Transformation Agency, Policy for the responsible use of AI in government, version 2.0 (effective 15 December 2025). https://www.digital.gov.au/ai/ai-in-government-policy
[R19] Department of Home Affairs / Cyber and Infrastructure Security Centre, Enhanced CIRMP Rules 2026 (commenced 10 June 2026) and SOCI Act Tranche 2 consultation paper (submissions closed 31 July 2026; proposals only). https://www.legislation.gov.au/F2026L00701; https://www.homeaffairs.gov.au/help-and-support/how-to-engage-us/consultations/proposed-amendments-to-streamline-and-modernise-the-soci-act-2018
[R20] Parliament of Australia, Joint Select Committee on Artificial Intelligence (appointed 20 August 2026; final report due 30 November 2026). https://www.aph.gov.au/Parliamentary_Business/Committees/Joint/Artificial_Intelligence
[R21] OAIC, Privacy (Children's Online Privacy) Code 2026 — exposure draft; must be finalised and registered by 10 December 2026. https://www.oaic.gov.au/privacy/privacy-registers/privacy-codes/childrens-online-privacy-code
[R22] Agreement between the United States and Australia on Access to Electronic Data for the Purpose of Countering Serious Crime (in force 30 January 2024). https://www.ag.gov.au/international-relations/international-crime-cooperation-arrangements/international-production-order-framework
[R23] Cyber Security Act 2024 (Cth), Part 3, and Cyber Security (Ransomware Payment Reporting) Rules 2025 — reporting from 30 May 2025 (Home Affairs). https://www.homeaffairs.gov.au/cyber-security-subsite/Pages/cyber-security-act.aspx

14. Open Issues and Peer-Review Questions (v0.3)

- Tier boundaries: is a four-tier scheme right, or should Medium split (commercial vs personal)? Reviewers from retail and super especially.
- HYOK guidance: current text says 'surgical, not universal' — challenge with concrete workloads where the feature-loss trade was or wasn't worth it.
- Level 6 definition: what evidence would convince a regulator that agentic remediation is itself well-governed? APRA's April 2026 AI letter (second-line capability to assess autonomous workflows; continuous monitoring proportionate to criticality) is the nearest supervisory signal [R14]. Is a 24-month Level 4–5 target (compressed from 36 in v0.3) credible for your sector? [Position]
- Utilities and education blueprints: expanded to full blueprints in v0.2 (Sections 10.5–10.6), anchored to the National AI assurance framework [R13] and SOCI [R5]; v0.3 updates them for the Enhanced CIRMP Rules and the draft Children's Online Privacy Code. Still open for peer-review contribution — nominate workloads and correct the obligations. [Position]
- Technology mappings: confirm AU-region service capabilities before publication; several evolve quarterly.